Microsoft Security

# Exploiting Token Based Authentication: Attacking and Defending Identities in the 2020s

Dr Nestori Syynimaa (MSTIC RnD)

**Jussi Roine | Microsoft MVP**
@JussiRoine

New social media & content strategy: Using the worst picture of myself in slides. That way, when people see me in real life they go "well you actually don't look THAT bad" 😆

In other news, my webinar with @Rencore #Microsoft365 Governance in 52 minutes: go.rencore.com/securing-micro...

4:08 PM · Apr 17, 2024 · **540** Views

Microsoft Security

# Who am I?

- Dr Nestori Syynimaa (DrAzureAD)
- Principal Identity Security Researcher
- Microsoft Threat Intelligence Center (MSTIC RnD)

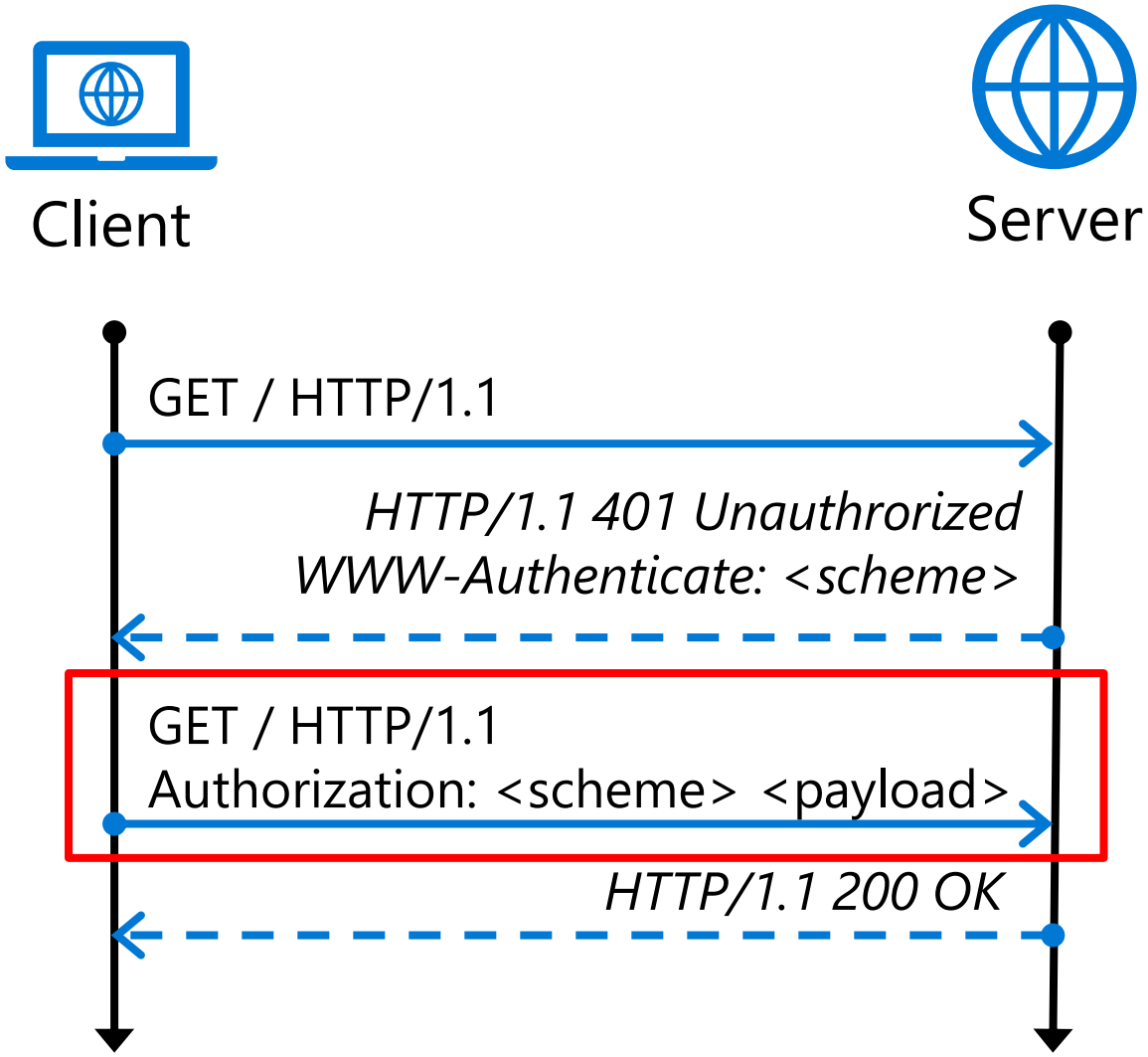
@DrAzureAD
nsyynimaa@microsoft.com

# Contents

- Introduction
- Federated authentication methods
- Token based authentication attacks
- Detecting & preventing

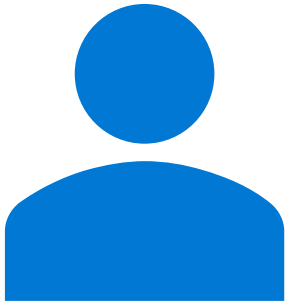
# Introduction

# General HTTP Authentication framework RFC 7235




- After the authentication, usually *session* cookies are used
- Some schemes:
  - Basic RFC 7617
  - Bearer RFC 6750
  - Negotiate / NTLM RFC 4599

# Key concepts



User

- Consumes services

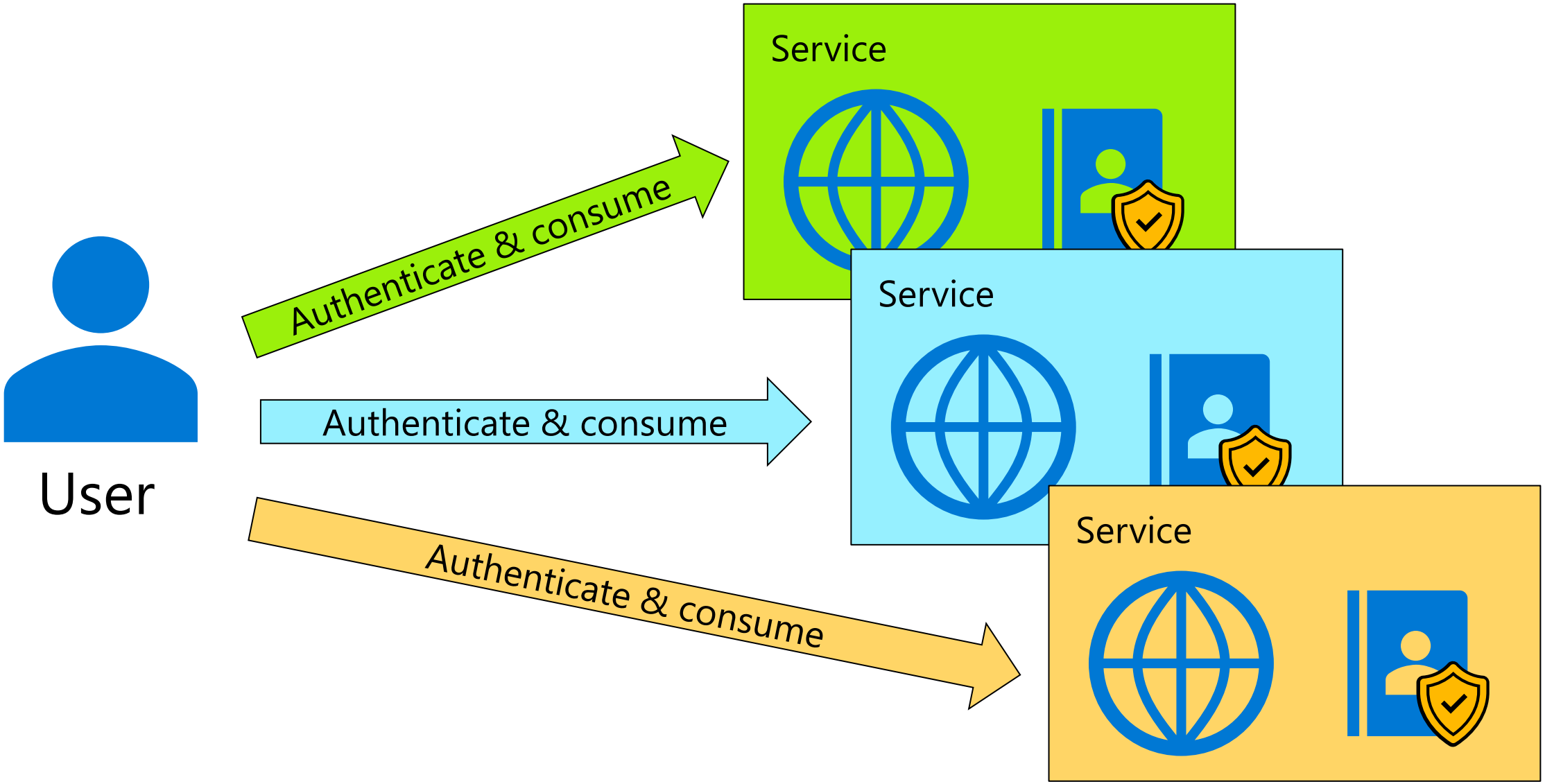
Service Provider (SP)

- Provides services

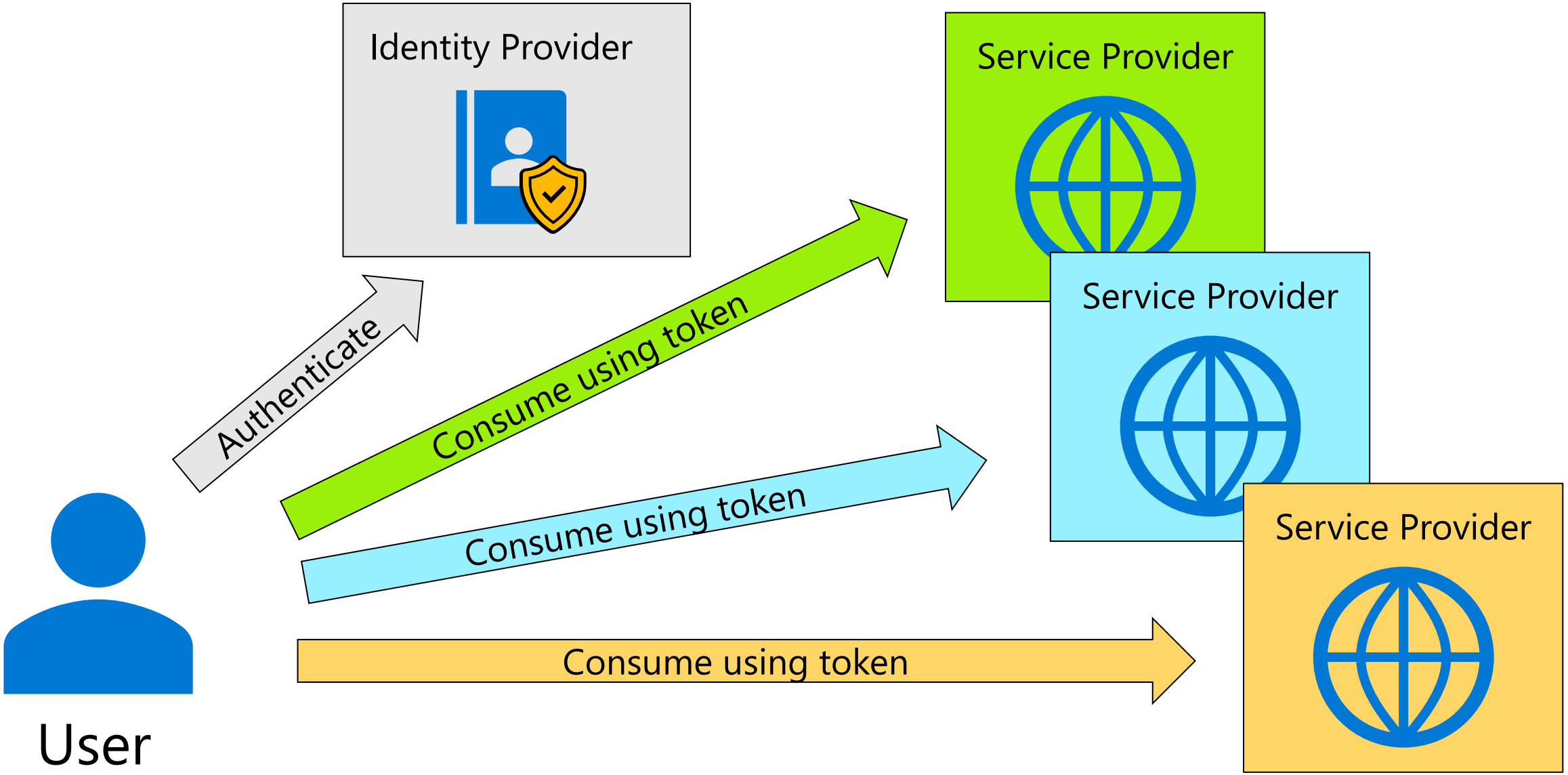
Identity Provider (IdP)

- Provides identity and access management

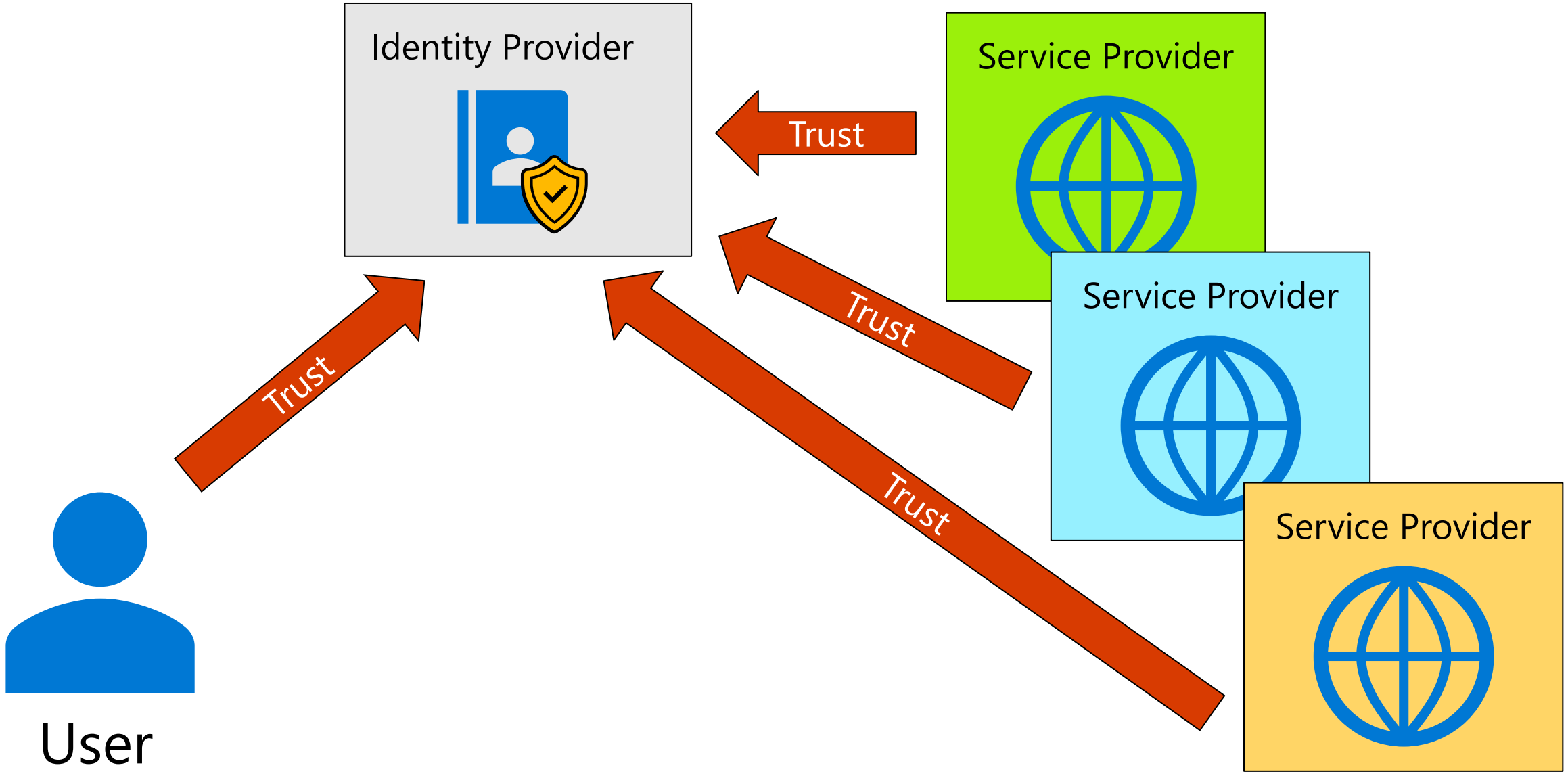
# Brief history of authentication: Silo model



# Brief history of authentication: Federated model (SSO)

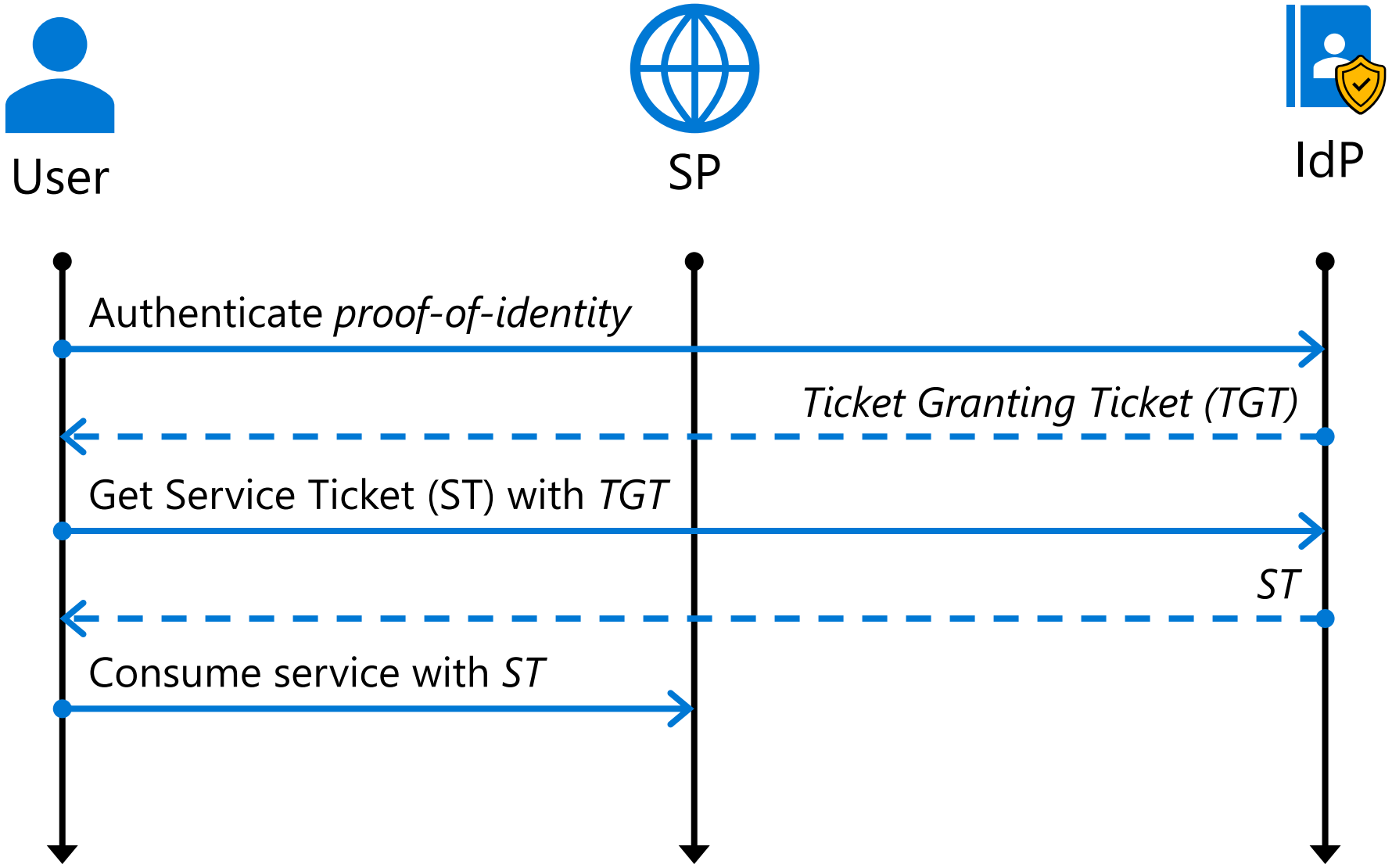


# Brief history of authentication: Federated model (SSO)

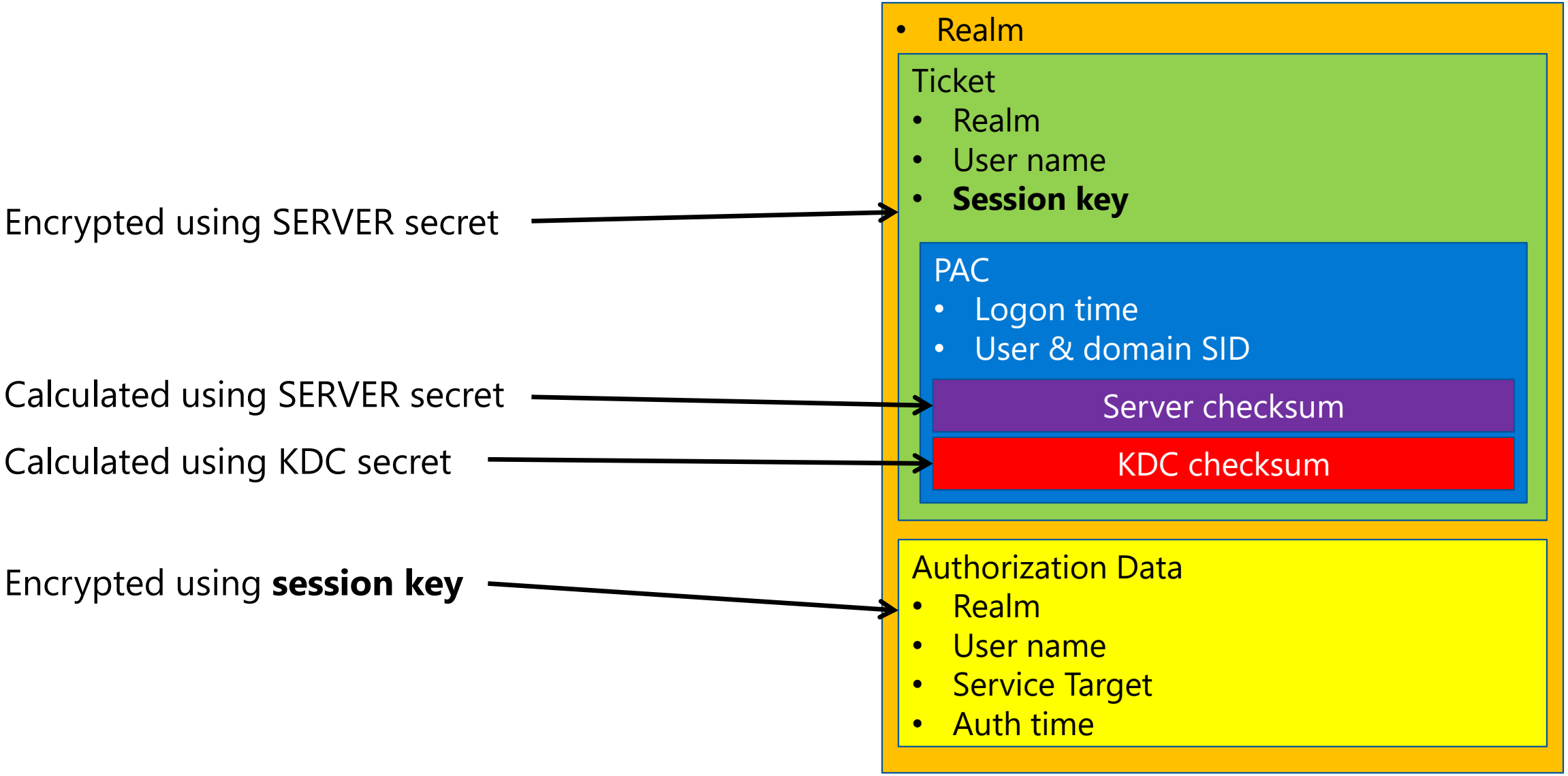


# Federated authentication methods

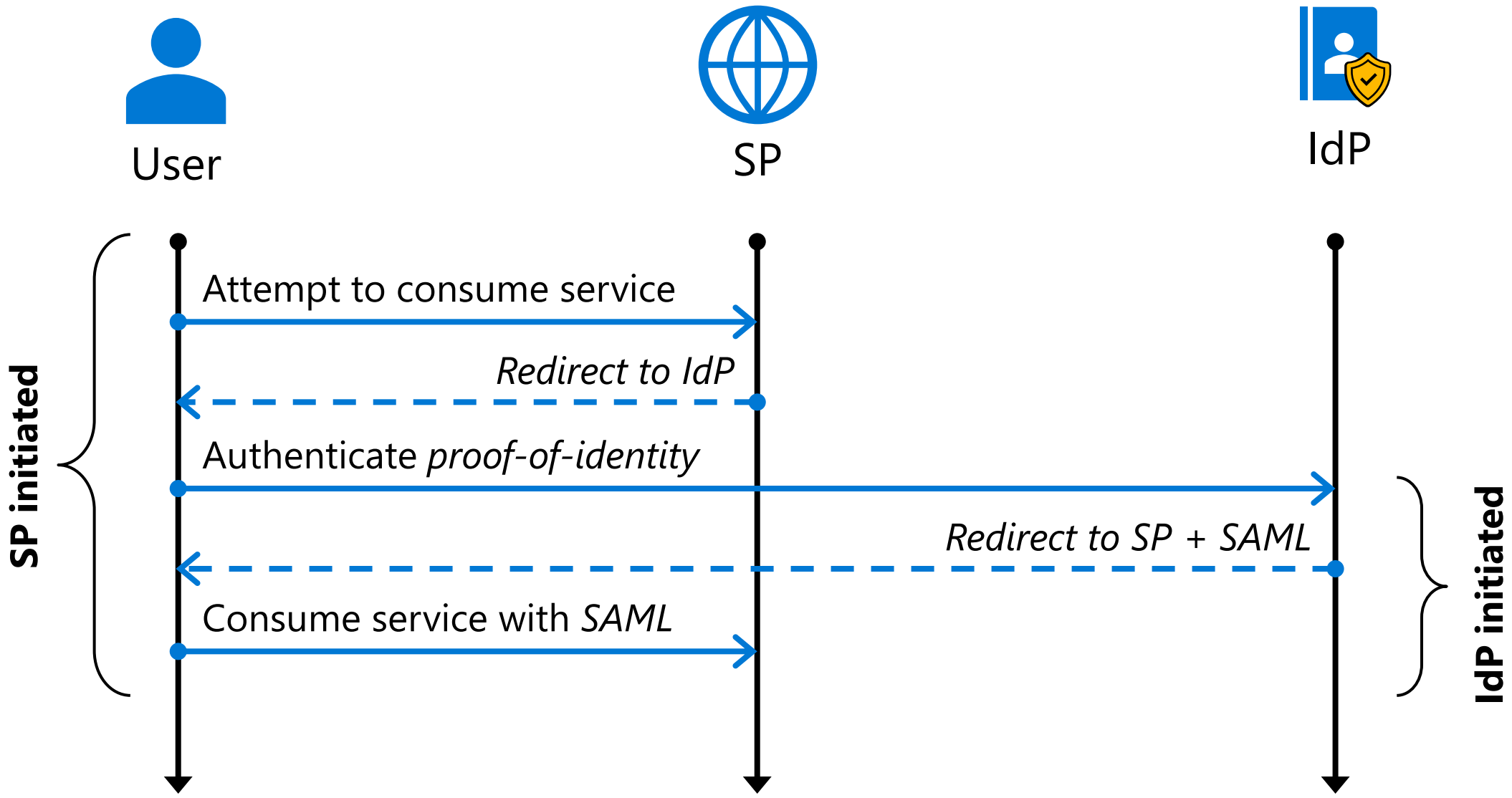
# Kerberos authentication flow



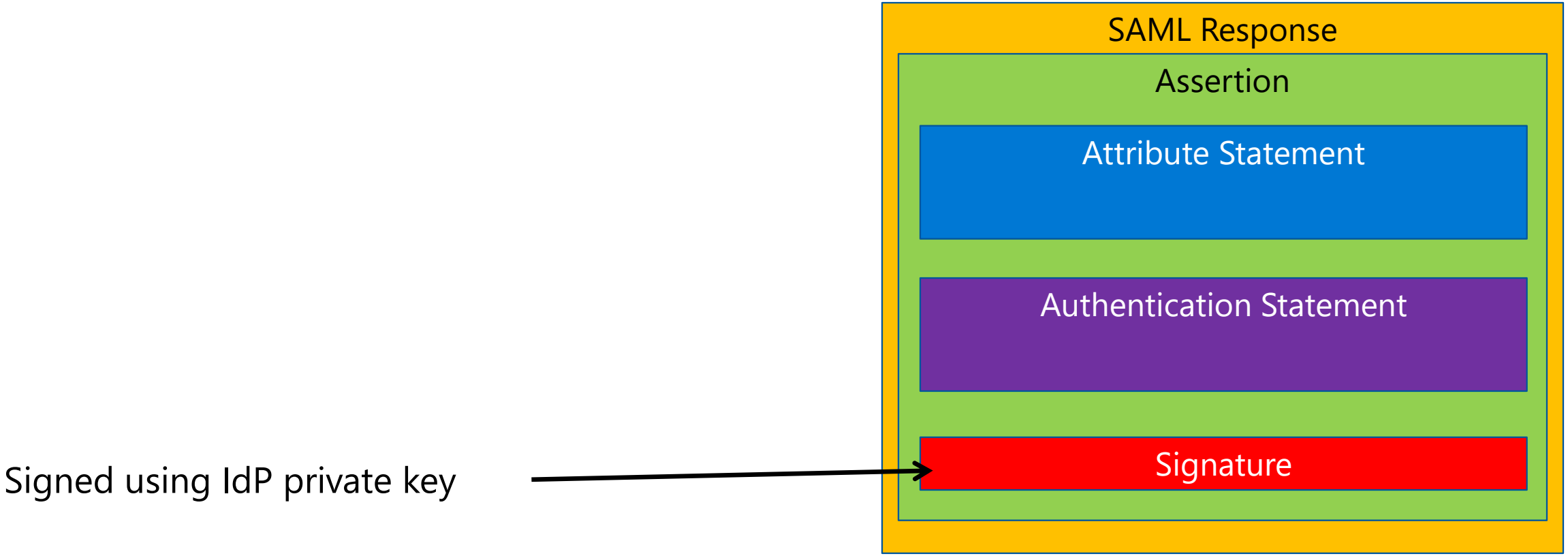
# Kerberos Application Request (KRB_AP_REQ) message



# SAML authentication flows



# SAML response message



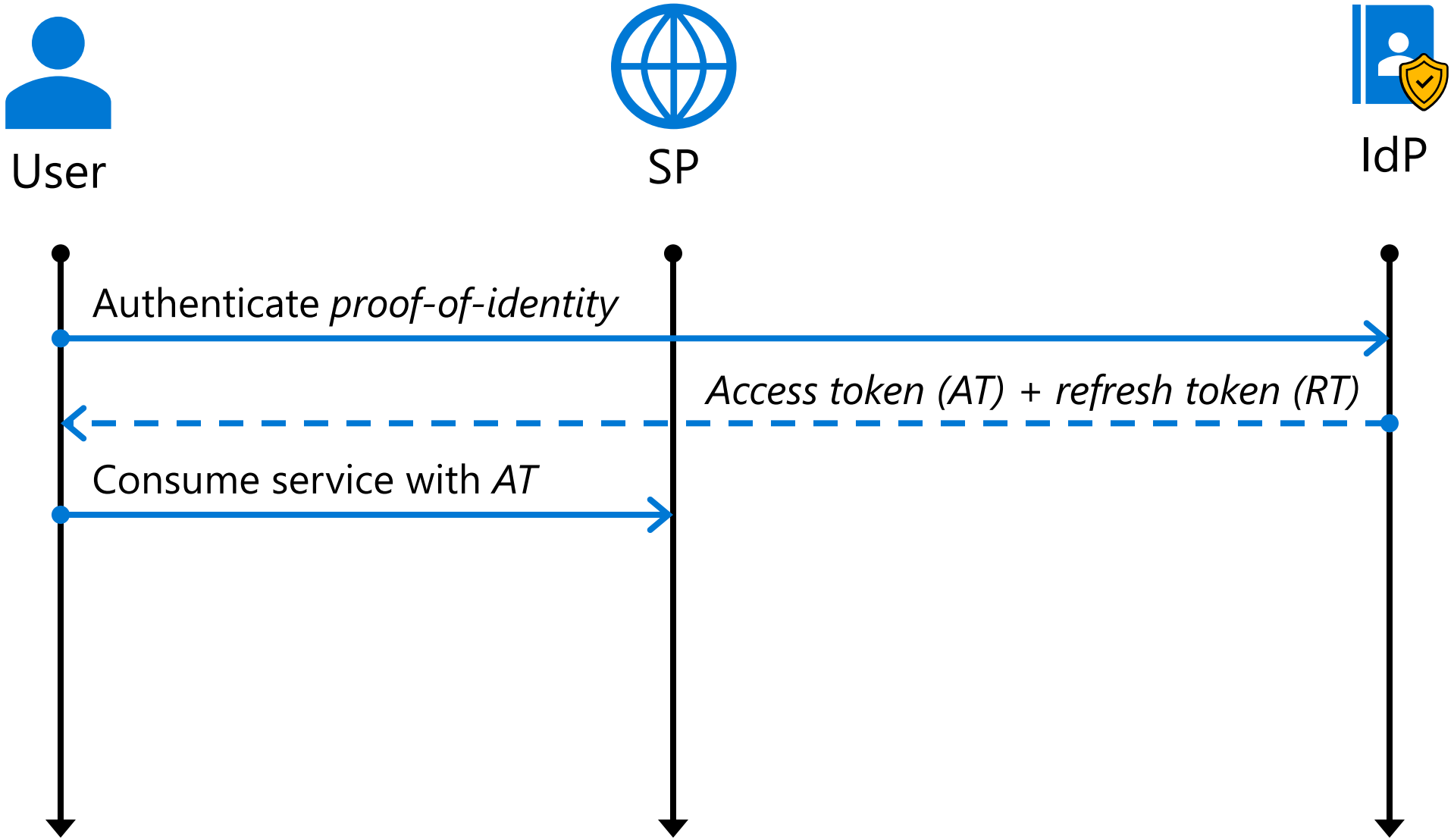
# JSON Web Signature (JWS)

- Used in Entra ID for Access & Id tokens
- Three parts
  - JOSE (Javascript Object Signing and Encryption) Header
  - Payload (usually a claims set as JSON)
  - Signature (optional)

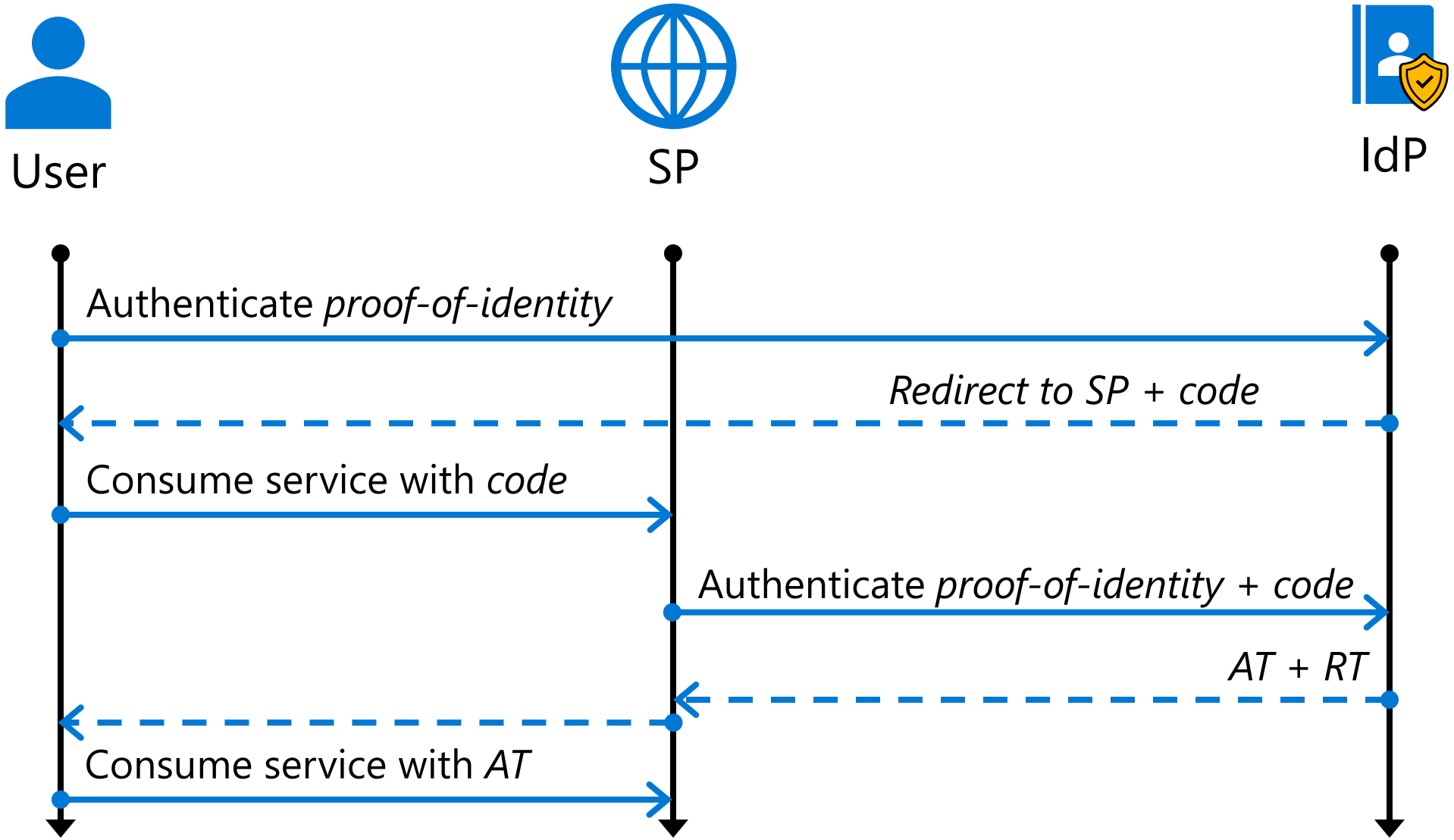
B64(UTF8(**JOSE Header**)) . B64(**Payload**) . B64(**Signature**)

https://www.rfc-editor.org/rfc/rfc7515.html

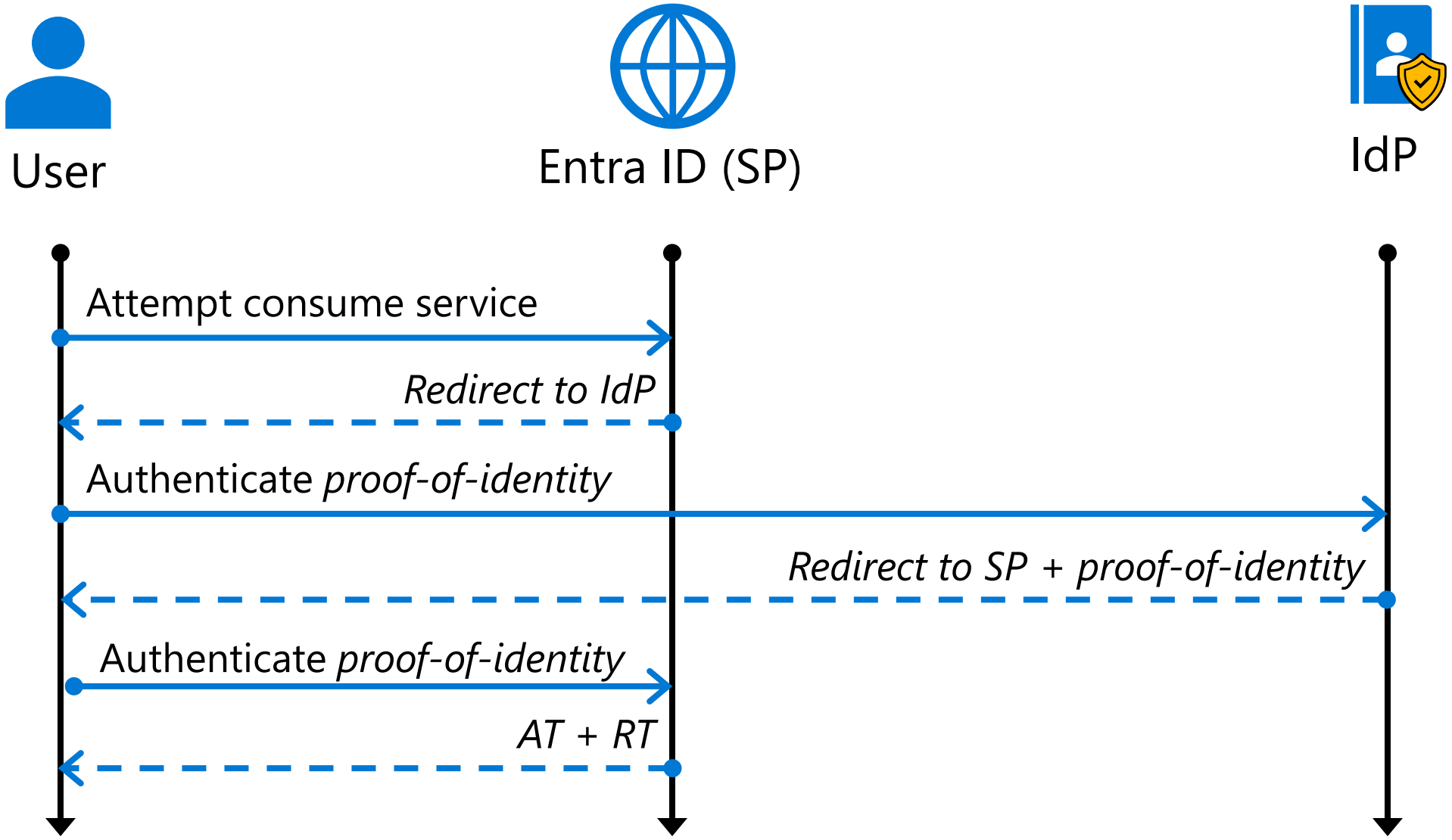
# Entra ID ROPC flow



# Entra ID authorization code flow



# Entra ID Hybrid authentication flow



# Entra ID Token types

| Token | Standard | Purpose | Lifetime | Can be revoked? |
|---|---|---|---|---|
| id_token | OpenID Connect | User identification | 1 h | No |
| access_token | OAuth2 | User (identification and) authorization | 1 h | No |
| refresh_token | OAuth2 | For requesting new access_token | 90 days | Yes |

# Summary of federated methods

| Protocol | Since | Format | Trust based on |
|---|---|---|---|
| Kerberos | 1989 | ASN.1 | Passwords |
| SAML | 2002 | XML | Certificates |
| OAuth | 2007 | JWT (JWS) | Certificates |

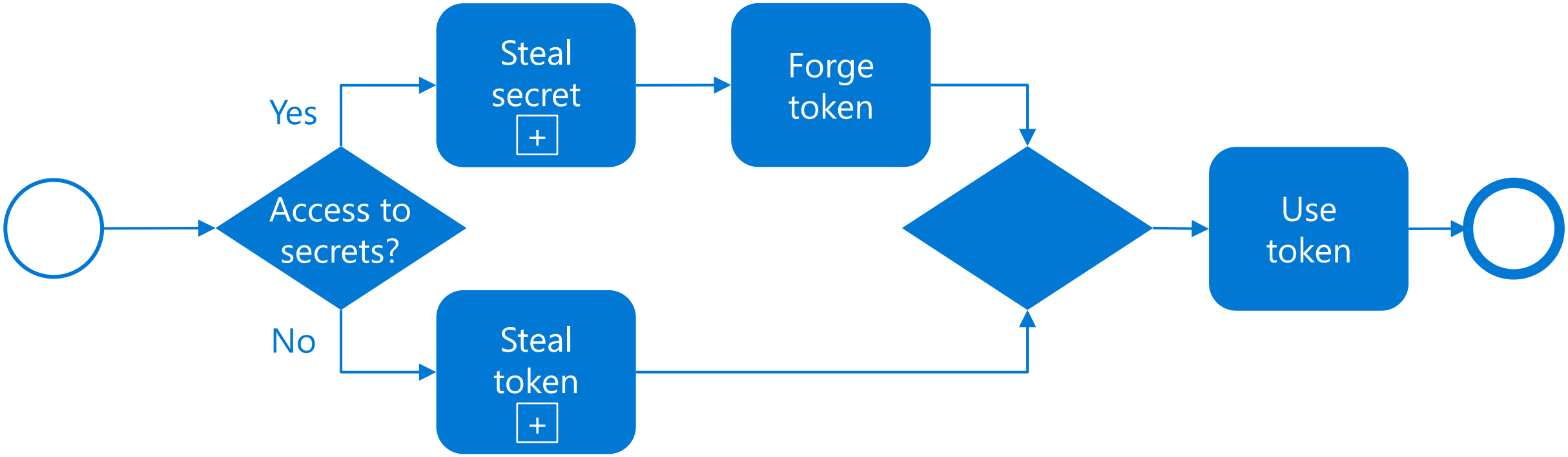
# Token-based authentication attacks

# Token based authentication

- Any party in possession of a bearer token (a "bearer") can use it to get access to the associated resources (without demonstrating possession of a cryptographic key). To prevent misuse, bearer tokens need to be protected from disclosure in storage and in transport.

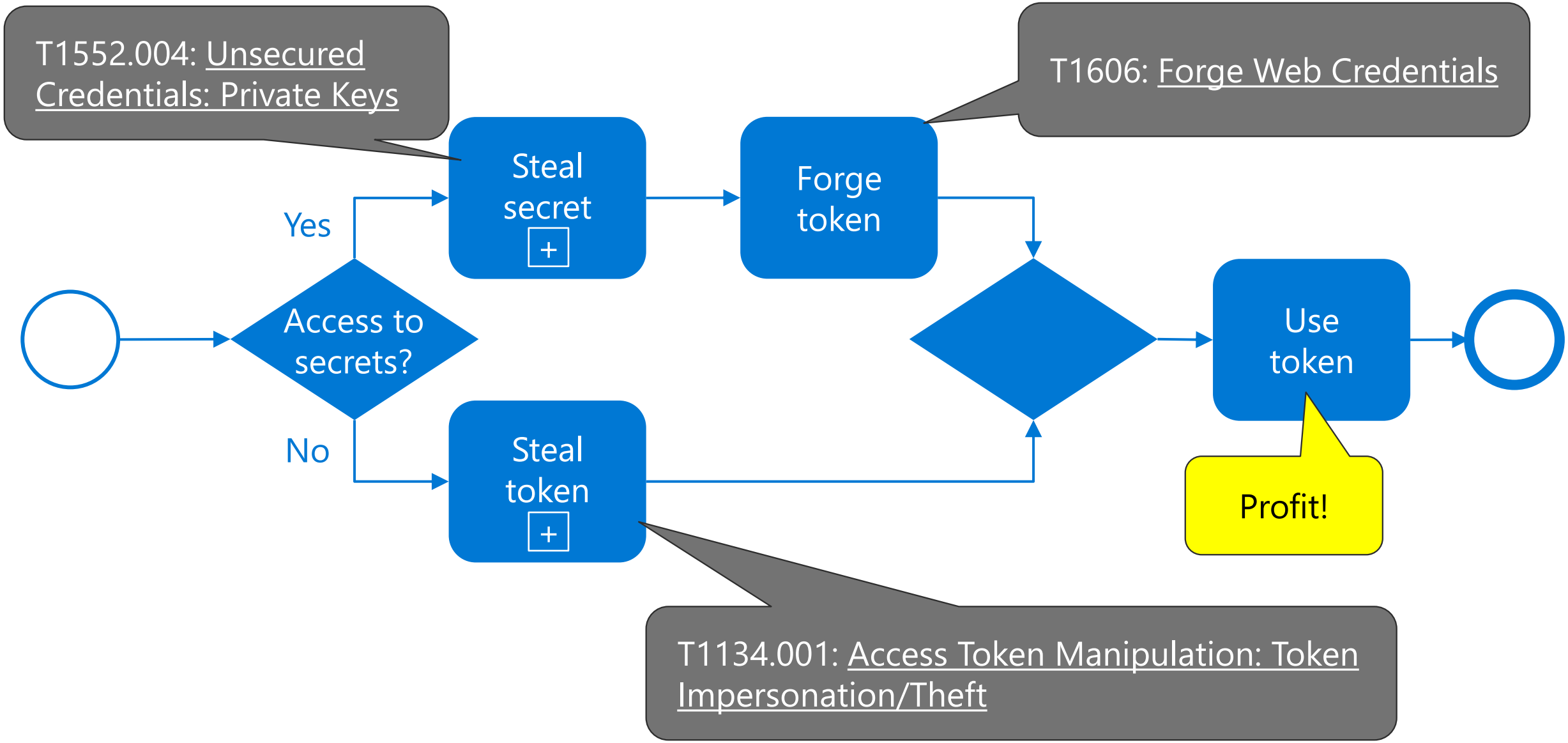
https://datatracker.ietf.org/doc/html/rfc6750

# Token-based authentication attack graph

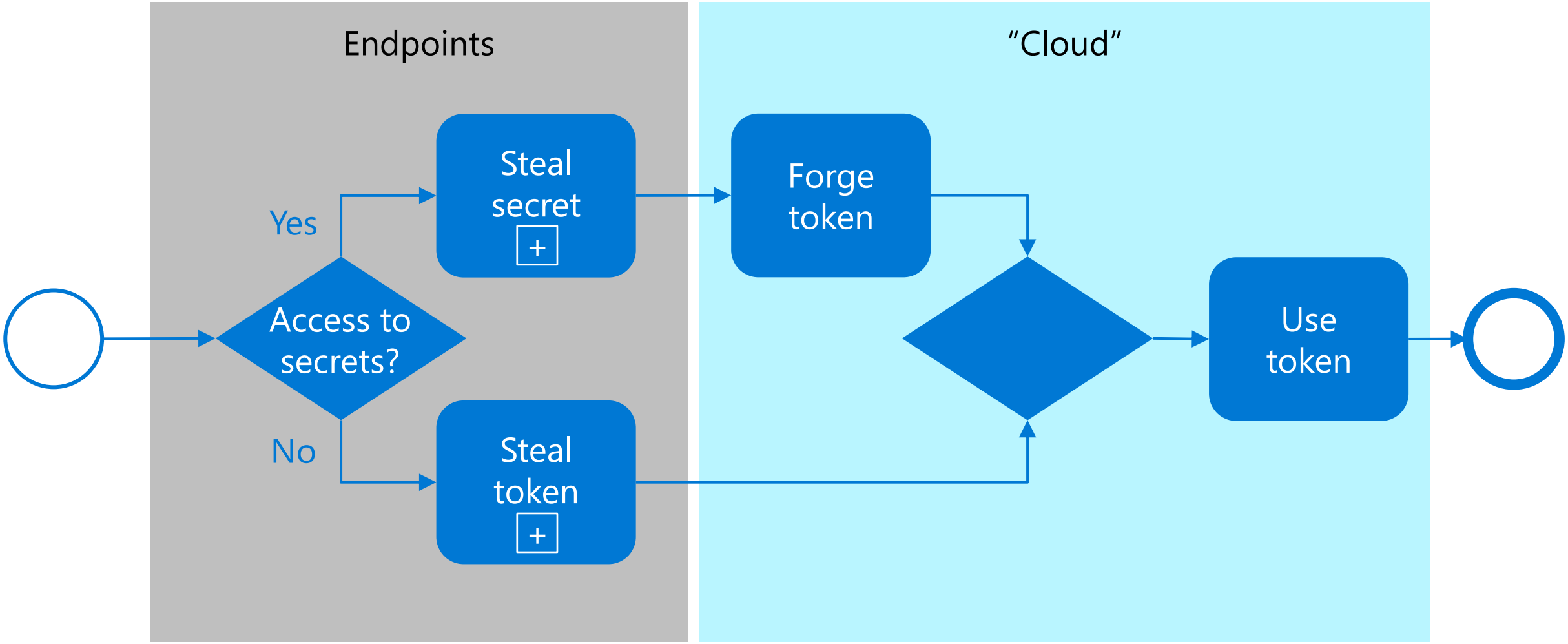



https://www.omg.org/spec/BPMN/2.0/

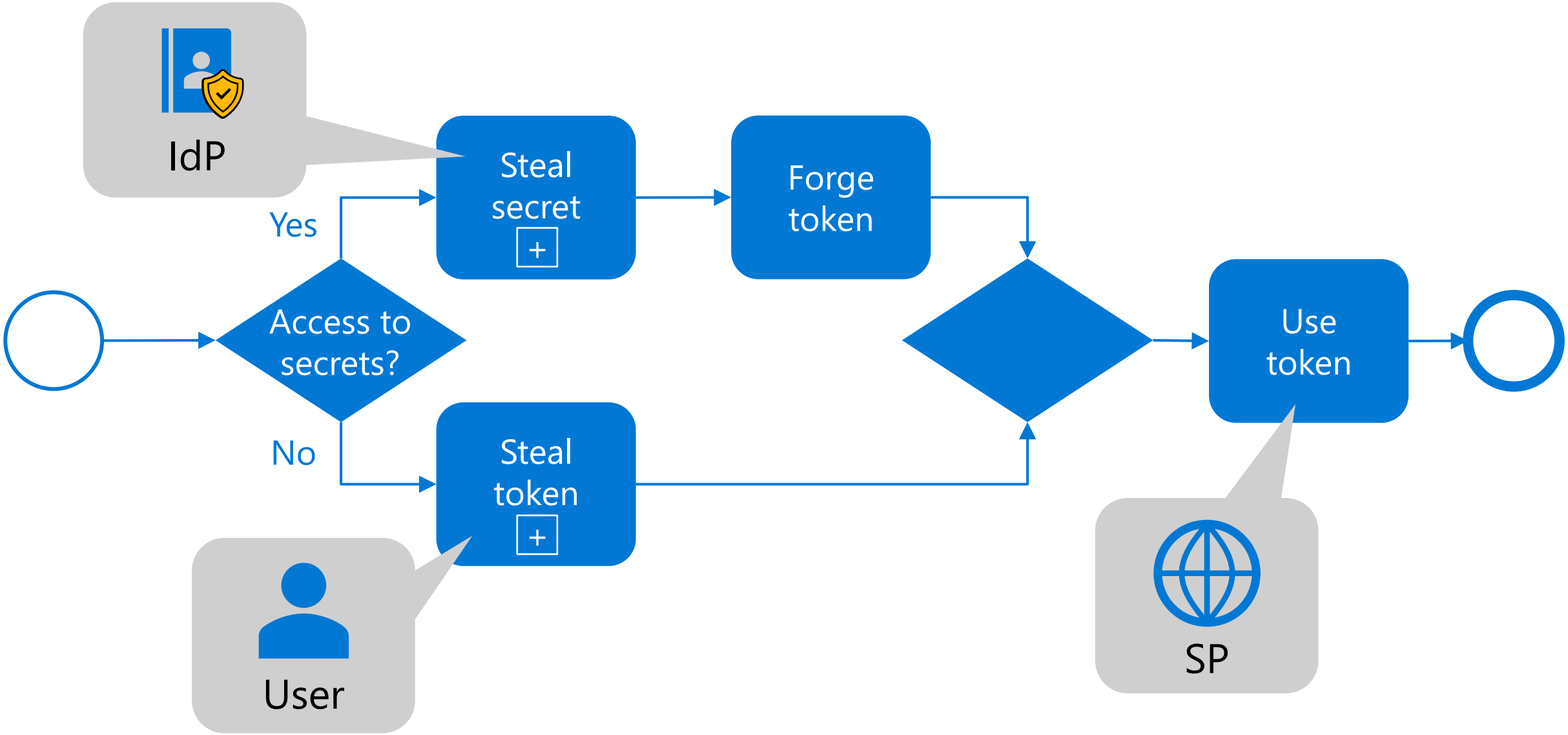
# MITRE ATT&CK® techniques



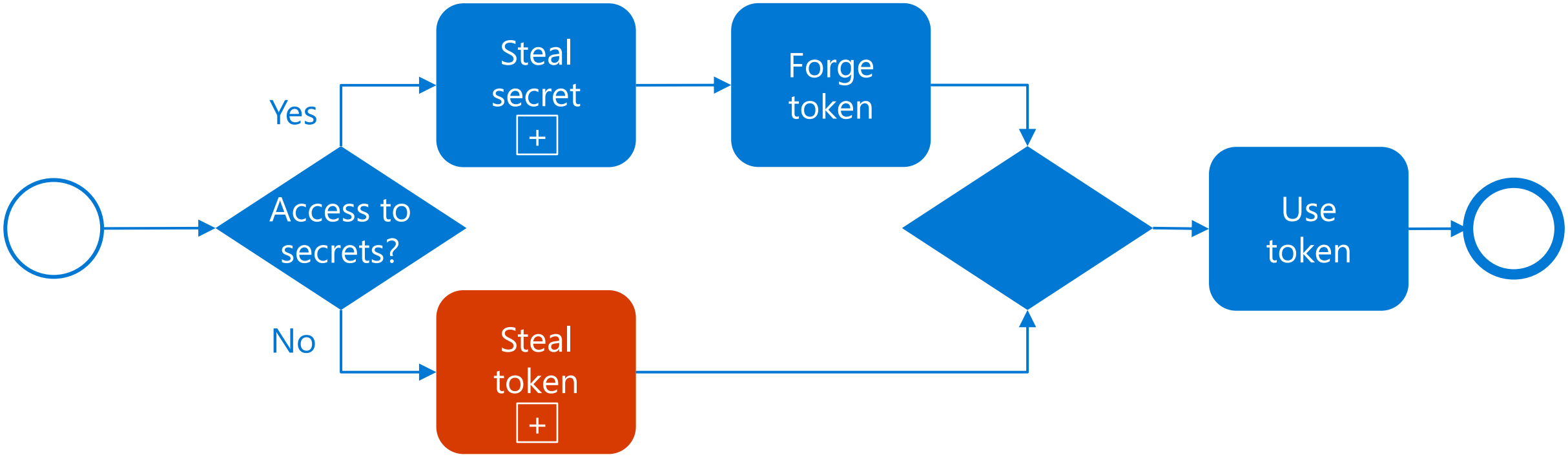
# Realms


Endpoints
"Cloud"
Yes
No
Access to secrets?
Steal secret
+
Steal token
+
Forge token
Use token

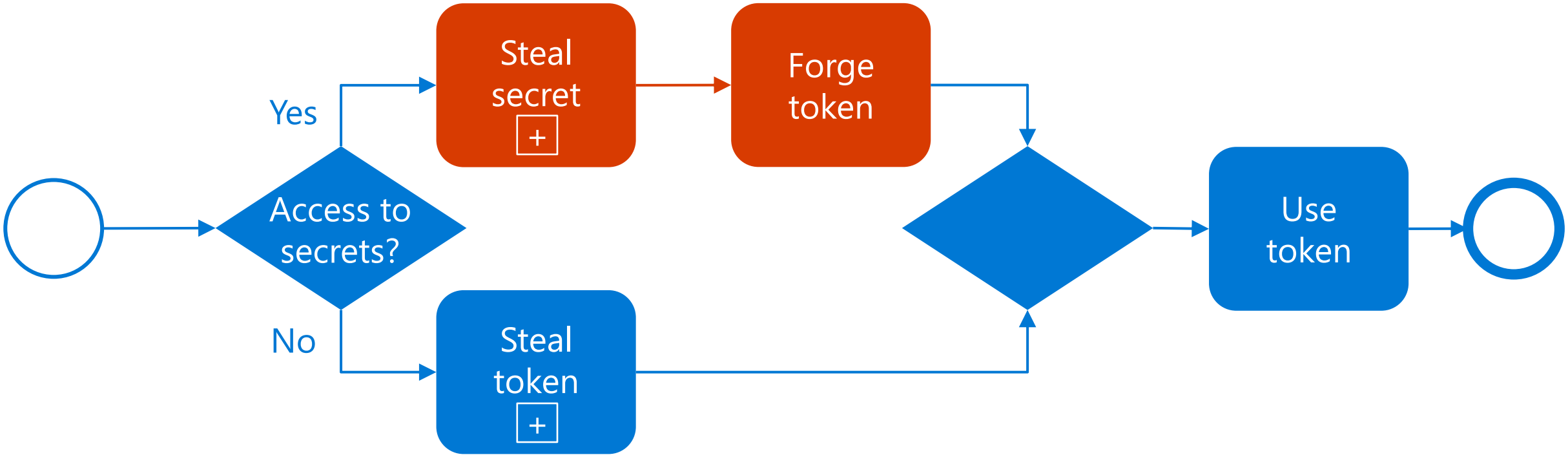
# Authentication roles



# Demo: Stealing tokens

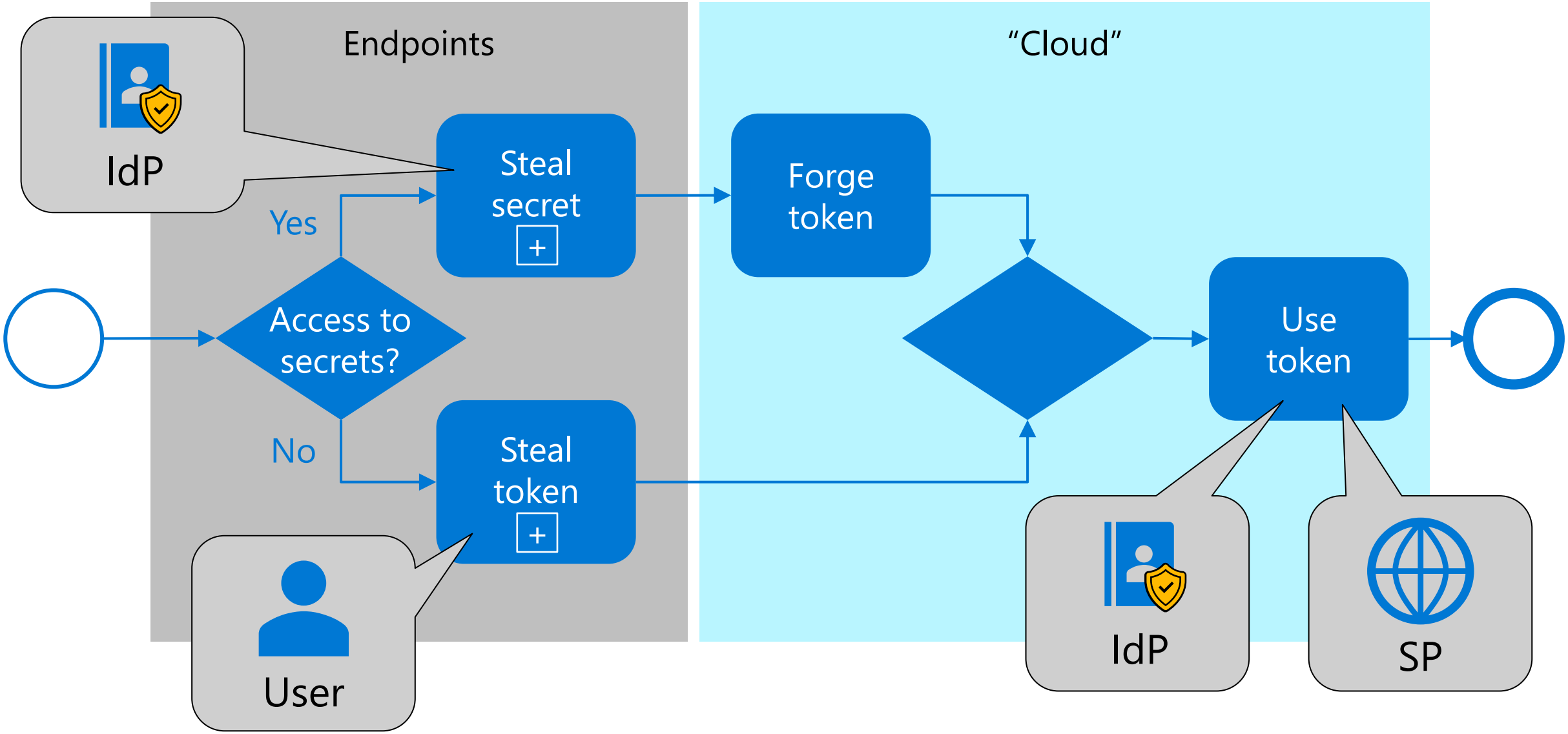


# Demo: Stealing secrets and forging tokens

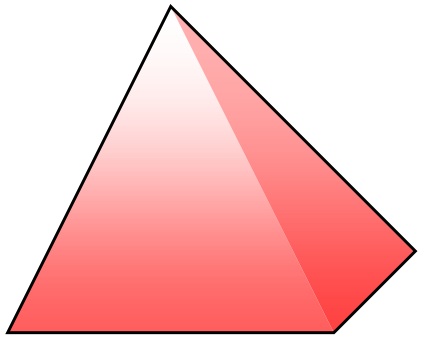


# Detecting & preventing

# Detection sources



# Scenario 1: On-prem identity



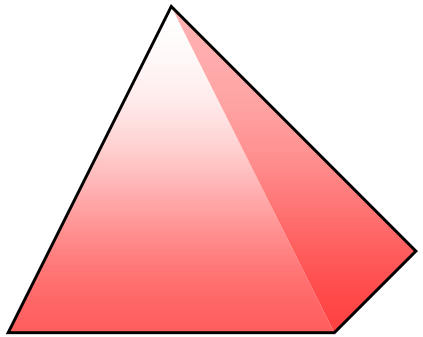
On-prem
Active Directory

On-prem
web server

Logon events

Usage logs

# Scenario 2: Hybrid identity



On-prem
Active Directory

On-prem
AD FS

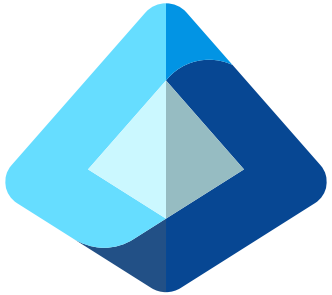
Entra ID

Logon events

AD FS audit
events

Sign-in logs

# Scenario 3: Cloud-only identity 1



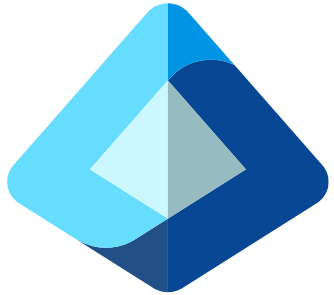
Entra ID

Azure Web App

Sign-in logs

Usage logs

# Scenario 4: Cloud-only identity 2



Entra ID

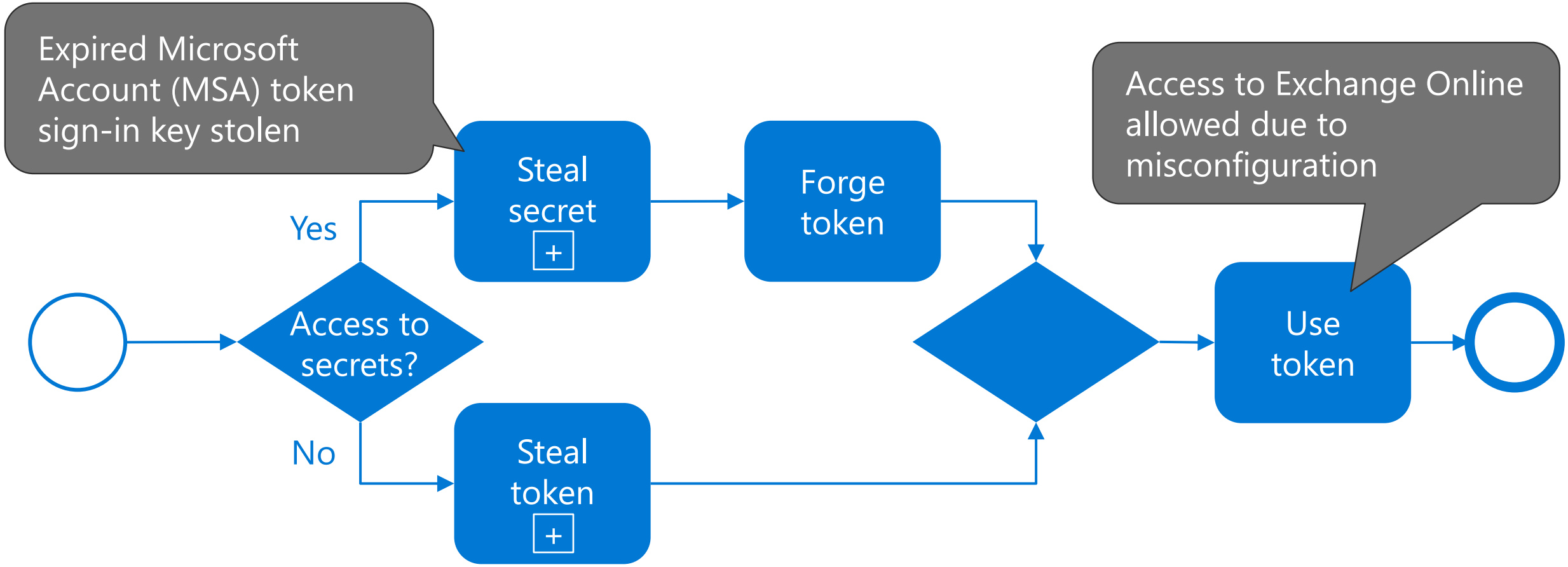
Microsoft 365

Sign-in logs

MS Graph Activity Logs

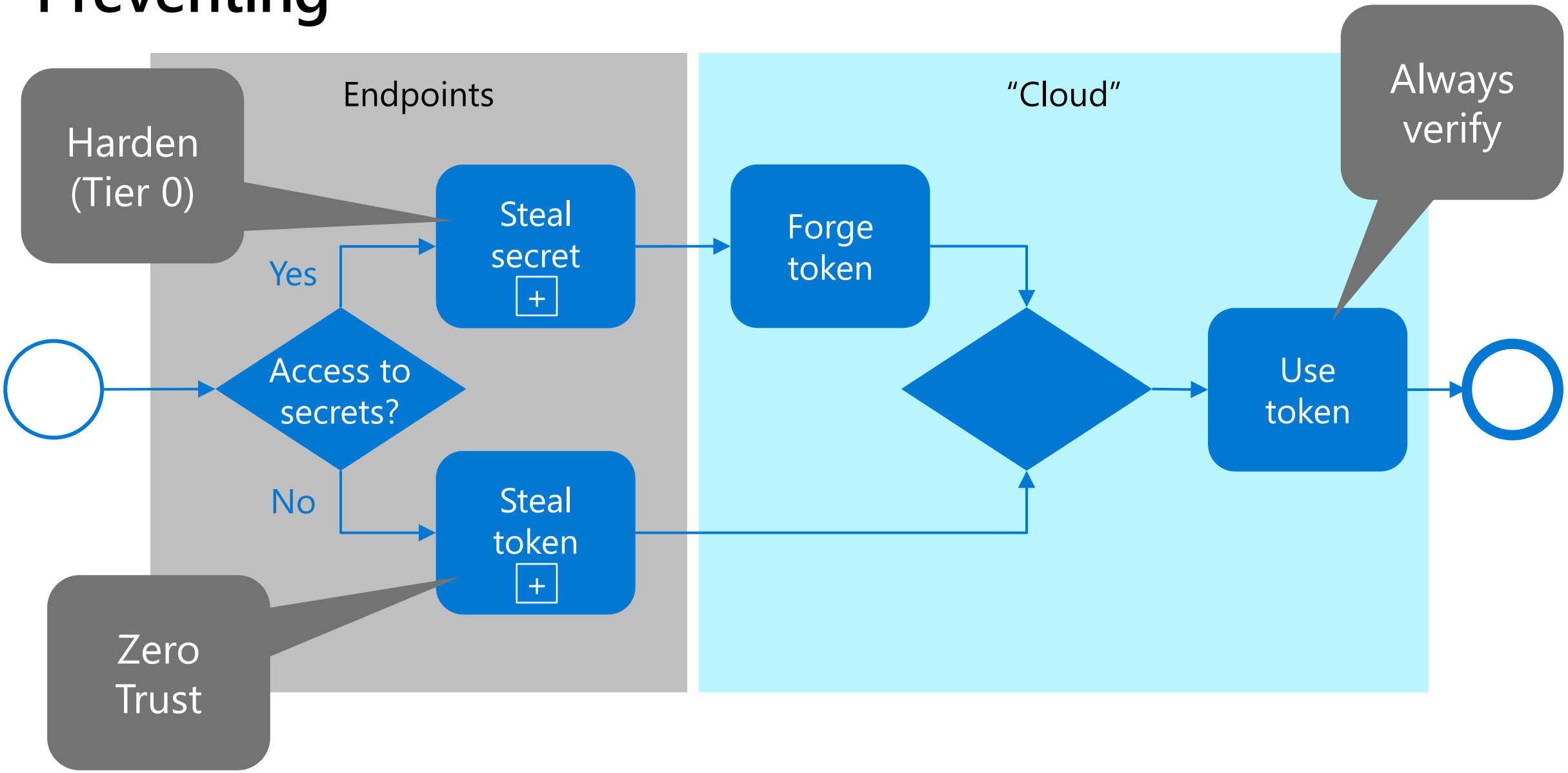
Unified audit log

# Storm-0558 accessed emails of 25 organisations




https://aka.ms/storm-0558
https://msrc.microsoft.com/blog/2023/07/microsoft-mitigates-china-based-threat-actor-storm-0558-targeting-of-customer-email/
https://msrc.microsoft.com/blog/2023/09/results-of-major-technical-investigations-for-storm-0558-key-acquisition/

# Preventing


Endpoints
"Cloud"
Harden (Tier 0)
Always verify
Steal secret
+
Forge token
Yes
Access to secrets?
Use token
No
Steal token
+
Zero Trust

# Summary

# Summary

- Stealing ***tokens*** gives temporary access as one person
- Stealing token sign-in ***secrets*** gives persistent access as any person
- Detecting and preventing token-theft is team sport
- Detection requires access to **IdP *and* SP** logs

Microsoft Security

© Copyright Microsoft Corporation. All rights reserved.